

RELAZIONE DI LABORATORIO

Analisi Dinamica di Malware in Ambiente Sandbox

Rilevamento, Comportamento e Contromisure relative alla Famiglia Vidar / Lumma Stealer

1. Introduzione

Nell'ambito delle attività di formazione in materia di sicurezza informatica, l'analisi dinamica del malware costituisce una competenza fondamentale per la comprensione delle tecniche, tattiche e procedure (TTP) impiegate dagli attori di minaccia contemporanei. Come evidenziato nel documento di riferimento allegato all'esercitazione, il panorama delle minacce cyber ha subito, nel biennio 2024-2025, una trasformazione significativa, caratterizzata da una crescente sofisticazione degli attacchi, dall'automazione resa possibile dall'Intelligenza Artificiale e da un incremento delle tensioni geopolitiche che si riflette anche sul piano digitale.

In tale contesto, gli infostealer rappresentano una delle categorie di malware più diffuse e redditizie per il cybercrime, in quanto orientati alla sottrazione sistematica di credenziali, token di autenticazione e dati sensibili, spesso propedeutica a successivi attacchi di più ampia portata (accesso iniziale per ransomware, frodi finanziarie, compromissione di account aziendali). La presente relazione documenta, con taglio accademico e metodologico, l'analisi di un campione appartenente a tale categoria, condotta interamente in un ambiente sandbox isolato e non riproducibile su sistemi reali, in ottemperanza ai principi etici e legali che disciplinano l'attività di ethical hacking.

Si precisa, in via preliminare e a scanso di equivoci, che l'intera attività descritta nel presente elaborato è stata svolta in un contesto di laboratorio didattico, con finalità esclusivamente formative e di ricerca difensiva, senza alcuna intenzione né possibilità di arrecare danno a sistemi, reti o soggetti terzi. Il campione analizzato è stato osservato in un ambiente di detonazione controllato (sandbox), che ne ha impedito qualsiasi propagazione o effetto collaterale al di fuori del contesto virtualizzato.

2. Obiettivi dell'Esercitazione

Coerentemente con le linee guida metodologiche fornite, l'esercitazione si è posta i seguenti obiettivi formativi:

- **Comprendere la catena di infezione** (kill chain) di un malware appartenente alla categoria degli infostealer, dalle fasi iniziali di esecuzione fino all'esfiltrazione dei dati e alla rimozione delle tracce.
- **Identificare e classificare le tecniche di evasione** impiegate dal campione, con particolare riferimento alle tecniche di masquerading e process injection.
- **Analizzare il traffico di rete generato**, individuando le comunicazioni verso infrastrutture di Command & Control e le richieste DNS verso domini sospetti.
- **Mappare le tecniche osservate** secondo il framework MITRE ATT&CK, al fine di produrre un'analisi standardizzata e confrontabile con la letteratura di settore.
- **Estrarre gli Indicatori di Compromissione (IoC)** rilevanti ai fini della condivisione con la comunità di threat intelligence e dell'implementazione di regole di rilevamento.
- **Proporre contromisure e strategie di mitigazione** coerenti con i framework di difesa moderni (Zero Trust, MFA resistente al phishing, monitoraggio comportamentale).

3. Metodologia di Analisi

3.1 Ambiente di Esecuzione

L'analisi è stata condotta impiegando la piattaforma ANY.RUN, un servizio di sandboxing interattivo che consente l'esecuzione di file potenzialmente malevoli all'interno di macchine virtuali isolate, con osservazione in tempo reale del comportamento del sistema. L'ambiente di test era costituito da una macchina virtuale Windows 10 a 64 bit (build 10.0.19041), configurata con un set standard di applicativi (browser Chrome e Firefox, suite Office, utility di sistema) al fine di simulare un endpoint aziendale realistico e favorire l'attivazione di eventuali routine di targeting selettivo da parte del malware.

3.2 Approccio Metodologico

L'analisi è stata condotta secondo un approccio di analisi dinamica comportamentale (behavioral dynamic analysis), che si contrappone all'analisi statica in quanto fondata sull'osservazione diretta delle azioni compiute dal campione durante la sua esecuzione, piuttosto che sulla sola ispezione del codice binario. Tale approccio risulta particolarmente efficace nei confronti di malware che impiegano tecniche di offuscamento, packing o anti-analisi statica, come tipicamente avviene nella famiglia di stealer oggetto del presente studio.

Il processo di analisi si è articolato nelle seguenti fasi operative:

Fase	Descrizione
1. Acquisizione del campione	Caricamento del file eseguibile nella sandbox
2. Detonazione controllata	Esecuzione del campione in ambiente virtualizzato isolato
3. Osservazione comportamentale	Monitoraggio di processi, chiamate di sistema, accessi al registro e al file system
4. Analisi del traffico di rete	Ispezione di richieste HTTP, DNS e connessioni verso infrastrutture esterne
5. Correlazione con signature note	Confronto con regole YARA e Suricata per l'identificazione della famiglia malware
6. Estrazione degli IoC	Raccolta sistematica di indicatori tecnici (IP, domini, hash, percorsi file)
7. Mappatura MITRE ATT&CK	Classificazione delle tecniche osservate secondo la matrice ATT&CK

3.3 Strumenti di Rilevamento Automatico

La piattaforma sandbox integra un motore euristico basato su regole YARA (per la classificazione statica di pattern noti) e Suricata (per l'analisi delle minacce di rete tramite regole Emerging Threats), i cui esiti sono stati impiegati come riscontro oggettivo a supporto dell'osservazione manuale del comportamento del campione.

4. Executive Summary dei Risultati

Parametro	Valore Rilevato
Livello di minaccia	Critico
Punteggio sandbox (ANY.RUN)	100/100 – Malicious
Famiglia malware identificata	Vidar Stealer, con firme di rete correlate a Lumma Stealer
Tipologia	Infostealer / Trojan
Obiettivo primario del malware	Esfiltrazione di credenziali salvate nei browser, cookie di sessione, token di autenticazione e informazioni di sistema
Piattaforma di analisi	ANY.RUN (Windows 10, build 10.0.19041)
Numero di processi generati	16
Richieste HTTP osservate	5
Richieste DNS osservate	16
Alert di rete (Network Threats)	8

Come illustrato in Figura 1, il campione, identificato dal file 66bddfcb52736_vidar.exe (hash MD5: FEB8687ED23F77925B35623027F799BB), è stato immediatamente classificato dalla piattaforma con il punteggio massimo di pericolosità, corredato da tag identificativi coerenti (vidar, lumma, stealer, loader), a conferma della natura ibrida del campione, riconducibile a un caricatore (loader) impiegato per la distribuzione di componenti stealer multipli.

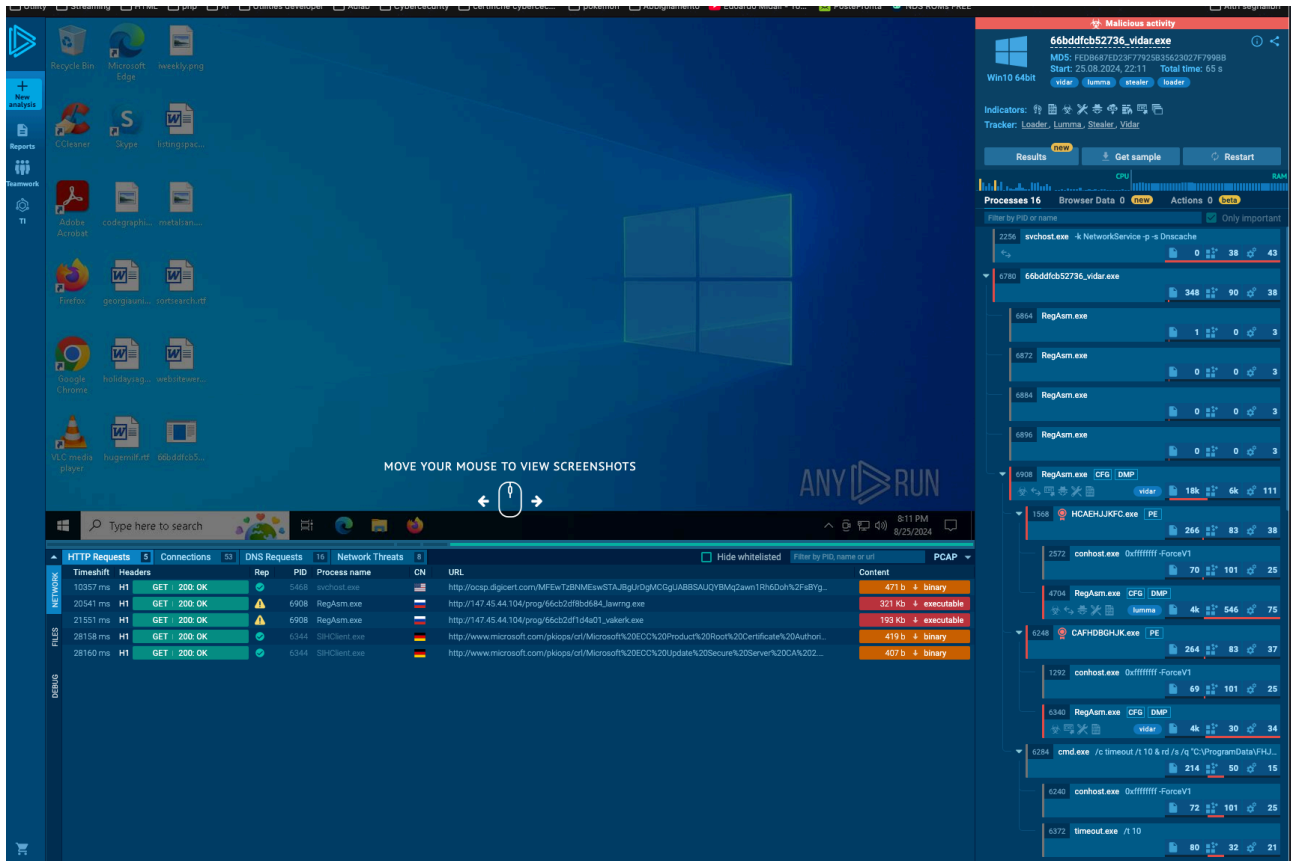


Figura 1 – Vista d'insieme della dashboard di analisi ANY.RUN, con indicazione del punteggio di pericolosità (100/100), dei tag identificativi della famiglia malware e dell'albero dei processi generati durante l'esecuzione del campione.

5. Analisi Tecnica Dettagliata della Catena di Infezione

5.1 Schema Sintetico della Kill Chain

[Esecuzione Iniziale] → [Process Hollowing] → [Furto Dati / DLL Dropping] → [C2 & Payload Secondari] → [Self-Deletion]			
HCAEHJJKFC.exe	RegAsm.exe (PID 6908)	Modulo Mozilla DLL	147.45.44.104
cmd.exe / timeout			

La catena di infezione osservata si articola in cinque fasi logiche distinte, di seguito descritte in dettaglio unitamente ai relativi riscontri probatori.

5.2 Fase 1 – Esecuzione Iniziale del Dropper

Attributo	Valore
PID	1568
Processo	HCAEHJJKFC.exe
Percorso di esecuzione	C:\ProgramData\HCAEHJJKFC.exe
Punteggio sandbox	100/100 – Malicious

L'analisi ha evidenziato come il processo iniziale presenti un nome file generato in modo pseudo-casuale (HCAEHJJKFC), tecnica comunemente impiegata per ostacolare il rilevamento basato su firma statica e per impedire l'attribuzione immediata da parte di soluzioni antivirus signature-based. Si è inoltre osservato come il file venga collocato nella directory C:\ProgramData\, percorso di sistema tipicamente dotato di permessi meno restrittivi rispetto alla cartella utente AppData, e frequentemente sfruttato da campioni

malevoli per eludere controlli di sicurezza focalizzati esclusivamente sui percorsi utente (cfr. Figura 7).

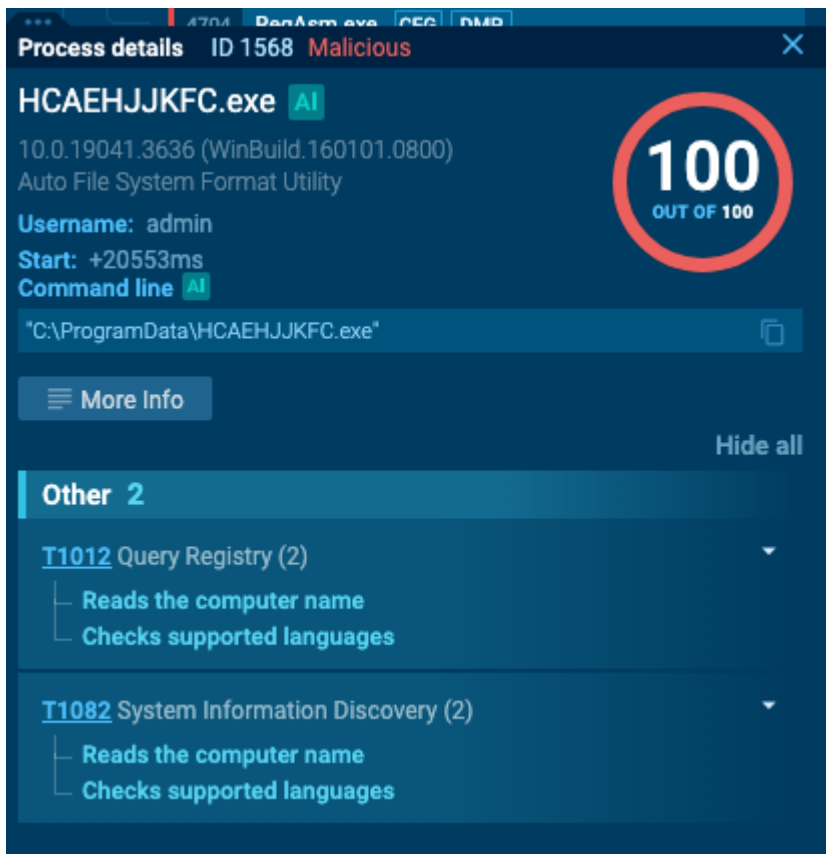


Figura 7 – Dettaglio del processo HCAEHJJKFC.exe (PID 1568), con evidenza del punteggio massimo di pericolosità e delle prime attività di ricognizione di sistema (lettura del nome computer, verifica delle lingue supportate).

5.3 Fase 2 – Evasione e Iniezione nel Processo Legittimo (Process Hollowing)

Attributo	Valore
PID	6908 / 6340
Processo target	RegAsm.exe
Percorso	C:\Windows\Microsoft.NET\Framework\v4.0.30319\RegAsm.exe

Il campione ha successivamente compromesso l'utility legittima RegAsm.exe (Assembly Registration Tool), componente nativo del framework Microsoft .NET, avviandola e iniettandovi il proprio codice malevolo mediante una tecnica riconducibile al process hollowing. Tale tecnica, classificata secondo il framework MITRE ATT&CK come T1036.003 – Masquerading: Rename System Utilities, consente al codice malevolo di operare sotto la copertura di un processo di sistema attendibile e digitalmente firmato, riducendo sensibilmente la probabilità di rilevamento da parte di soluzioni di sicurezza basate su whitelist di processi o su euristiche di reputazione.

La piattaforma di analisi ha inoltre generato un riscontro positivo mediante motore a firme YARA, con l'alert esplicito “VIDAR has been detected (YARA)” (Figura 3), a conferma inequivocabile dell'attribuzione del

campione

alla

famiglia

Vidar

Stealer.



Figura 3 – Pannello dei dettagli del processo RegAsm.exe (PID 6908), con evidenza delle quattro categorie di comportamento a rischio elevato (Danger), tra cui il furto di credenziali dai browser (T1555.003) e il rilevamento della firma YARA specifica per la famiglia Vidar.



Figura 10 – Dettaglio del processo RegAsm.exe (PID 6340), istanza secondaria generata dal medesimo dropper, anch'essa positiva alla firma YARA di Vidar, a conferma della persistenza del comportamento malevolo su più rami del processo.

5.4 Fase 3 – Ricognizione di Sistema e Furto di Credenziali (Stealer Activity)

Una volta ottenuta l'esecuzione all'interno del processo ospite, il payload ha eseguito una sequenza strutturata di operazioni tipiche della categoria infostealer, di seguito distinte in due sotto-fasi.

5.4.1 Discovery e Ricognizione del Sistema

Come documentato in Figura 4, Figura 5 e Figura 6, il malware ha condotto un'estesa attività di ricognizione, riconducibile alle seguenti tecniche MITRE ATT&CK:

- **T1082 – System Information Discovery:** lettura delle informazioni relative alla CPU, delle variabili d'ambiente, del Machine GUID dal registro di sistema, del nome del computer, della data di installazione del sistema operativo e delle lingue supportate.
- **T1614 – System Location Discovery:** verifica delle impostazioni di localizzazione geografica e linguistica del sistema target, funzionale a possibili logiche di targeting geografico o di evasione di ambienti sandbox associati a specifiche region.
- **T1518 – Software Discovery:** enumerazione delle applicazioni e dei software installati sul sistema compromesso.

- **T1012 – Query Registry:** interrogazione estensiva del registro di sistema, incluse le impostazioni proxy, i criteri di sicurezza software e le impostazioni di attendibilità di Windows.
- **T1497.003 – Time Based Evasion (Checks):** verifica della data di installazione del sistema operativo, tecnica riconducibile a controlli anti-sandbox basati sull'età del sistema.

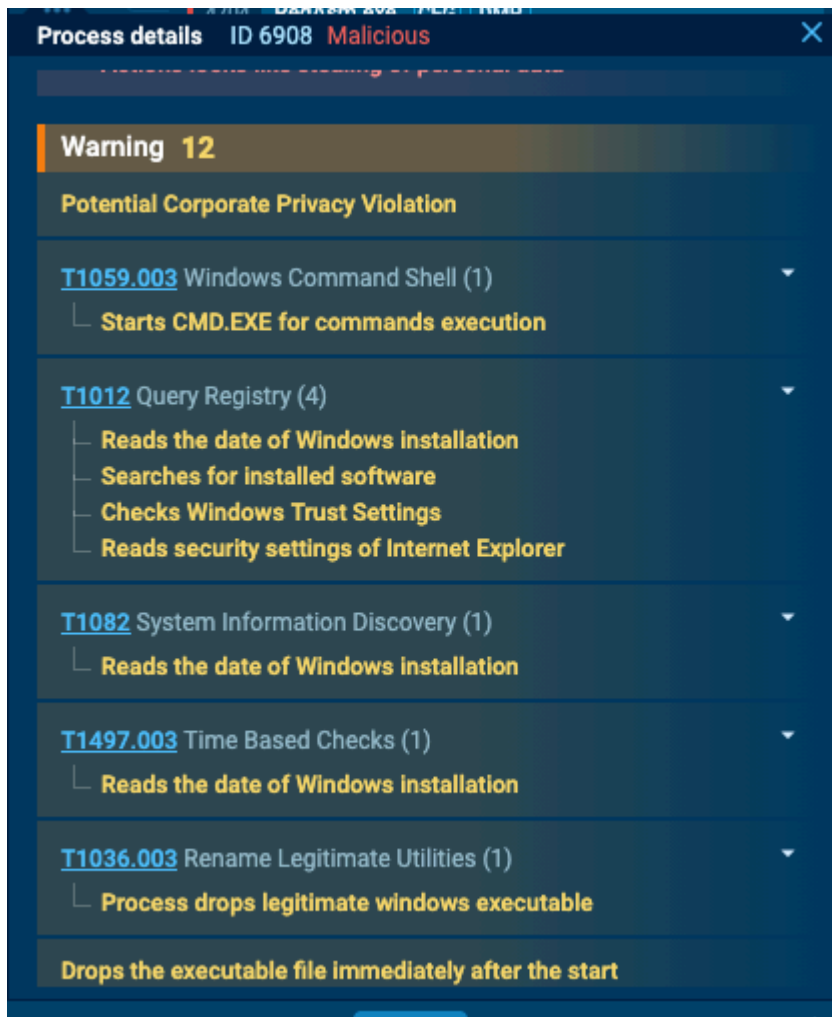


Figura 4 – Elenco delle dodici categorie di avviso (Warning) rilevate per il processo RegAsm.exe, comprendenti tecniche di ricognizione del registro, verifica delle impostazioni di sicurezza di Internet Explorer e rilevamento di software installato

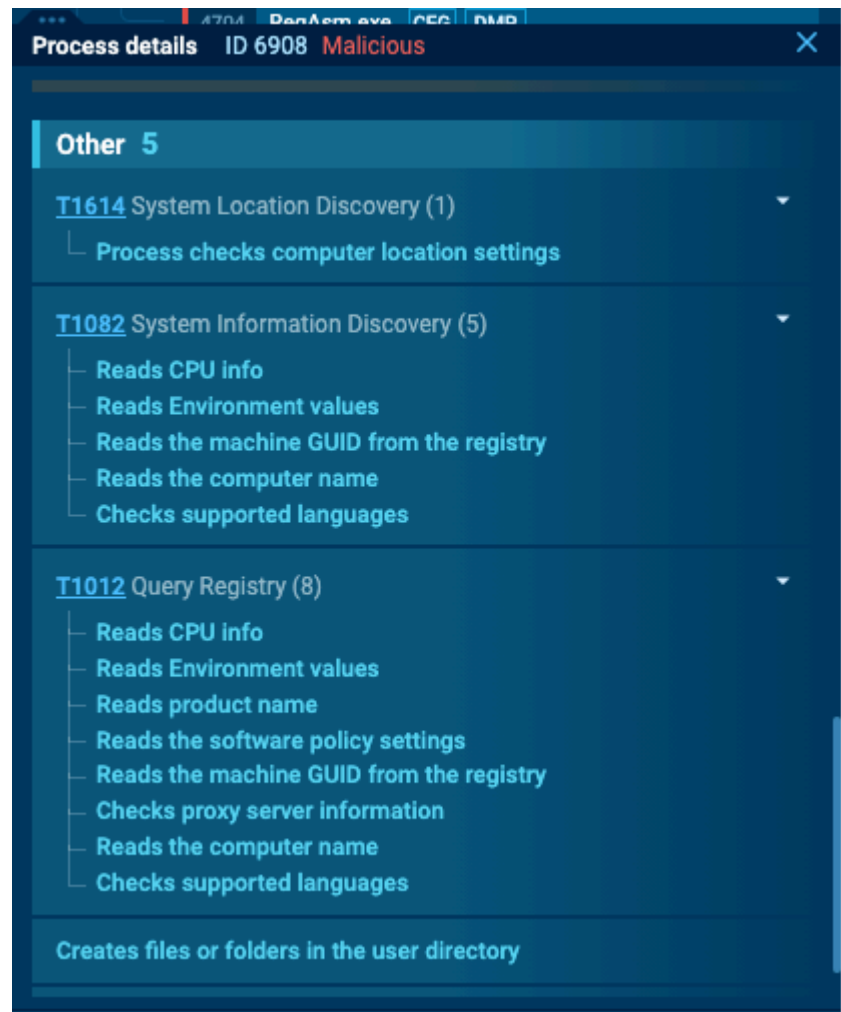


Figura 6 – Dettaglio delle attività di System Information Discovery e Query Registry, con evidenza puntuale delle singole chiavi di registro e dei parametri di sistema interrogati dal processo malevolo.

5.4.2 Furto di Dati e Sottrazione delle Credenziali

L'analisi ha successivamente rilevato le seguenti tecniche di esfiltrazione, direttamente riconducibili alla finalità primaria del campione:

- **T1555.003 – Credentials from Web Browsers**: estrazione delle password memorizzate nei browser basati su motore Chromium (Google Chrome) e nel browser Mozilla Firefox.
- **T1539 – Steal Web Session Cookie**: sottrazione dei cookie di sessione attiva, tecnica che consente il bypass dell'autenticazione multi-fattore mediante riutilizzo di sessioni già autenticate (session hijacking).
- **DLL Dropping**: rilascio di librerie dinamiche (DLL) riconducibili al motore Mozilla, finalizzato alla decifratura locale dei file di profilo Firefox (key4.db, logins.json), nei quali sono custodite le credenziali salvate dall'utente.



Figura 5 – Evidenza delle tecniche T1539 (Steal Web Session Cookie) e T1555.003 (Credentials from Web Browsers), correlate al rilascio delle librerie DLL di Mozilla necessarie alla decifratura locale delle credenziali salvate nel browser Firefox.

5.5 Fase 4 – Attività di Rete, Comunicazione C2 e Download di Payload Secondari

L'analisi del traffico HTTP, DNS e degli alert di sicurezza di rete ha permesso di ricostruire in maniera dettagliata l'infrastruttura di Command & Control impiegata dal campione.

5.5.1 Richieste HTTP e Download di Componenti Aggiuntivi

Come riportato in Figura 12, sono state osservate cinque richieste HTTP, tra le quali due dirette verso un medesimo indirizzo IP esterno, riconducibile all'infrastruttura C2:

PID	Processo	URL	Contenuto
6908	RegAsm.exe	http://147.45.44.104/prog/66cb2df8bd684_lawrng.exe	Eseguibile (321 KB)
6908	RegAsm.exe	http://147.45.44.104/prog/66cb2df1d4a01_vakerk.exe	Eseguibile (193 KB)

HTTP Requests 5 Connections 53 DNS Requests 16 Network Threats 8									
Timeshift	Headers	Rep	PID	Process name	CN	URL	Content		
10357 ms	H1 GET 200: OK	✓	5468	svchost.exe		http://ocsp.digicert.com/MFEwTzBNMEswSTAJBgUrDgMCGGUABBSAUQYBMq2awn1Rh6Doh%2FsByg...	471 b	binary	
20541 ms	H1 GET 200: OK	⚠	6908	RegAsm.exe		http://147.45.44.104/prog/66cb2df8bd684_Jawrng.exe	321 Kb	executable	
21551 ms	H1 GET 200: OK	⚠	6908	RegAsm.exe		http://147.45.44.104/prog/66cb2df1d4a01_vakerk.exe	193 Kb	executable	
28158 ms	H1 GET 200: OK	✓	6344	SIHClient.exe		http://www.microsoft.com/pkiops/crl/Microsoft%20ECC%20Product%20Root%20Certificate%20Authori...	419 b	binary	
28160 ms	H1 GET 200: OK	✓	6344	SIHClient.exe		http://www.microsoft.com/pkiops/crl/Microsoft%20ECC%20Update%20Secure%20Server%20CA%202...	407 b	binary	

Figura 12 – Elenco delle richieste HTTP osservate durante l'esecuzione del campione, con evidenza delle due richieste dirette verso l'indirizzo IP 147.45.44.104, classificate come traffico a rischio dal motore di reputazione della sandbox.

Tale comportamento è riconducibile alla tecnica T1105 – Ingress Tool Transfer, in cui il campione, dopo aver ottenuto l'esecuzione iniziale, provvede al download di ulteriori componenti eseguibili dal server di controllo, verosimilmente finalizzati all'estensione delle capacità del malware o al deployment di ulteriori payload malevoli sul sistema compromesso.

5.5.2 Risoluzione DNS di Domini Sospetti

L'ispezione delle richieste DNS (Figura 13) ha rilevato la risoluzione dei seguenti domini, ritenuti di natura malevola:

- **caffegclasiqwp.shop**: dominio segnalato con indicatore di reputazione negativo e correlato, secondo le regole Suricata, a infrastrutture di comando e controllo.
- **arpdabl.zapto.org**: dominio appartenente al servizio di Dynamic DNS (DynDNS) No-IP/ZapTo, tecnica frequentemente impiegata dagli attori di minaccia per mantenere la raggiungibilità dell'infrastruttura C2 anche in presenza di variazioni dell'indirizzo IP sottostante.

HTTP Requests 5 Connections 53 DNS Requests 16 Network Threats 8									
Timeshift	Status	Rep	Domain	IP					
BEFORE	Responded	✓	settings-win.data.microsoft.com	40.127.240.158					
BEFORE	Responded	✓	google.com	142.250.186.46					
BEFORE	Responded	✓	settings-win.data.microsoft.com	4.231.128.59					
2573 ms	Responded	✓	steamcommunity.com	23.212.216.106					
5578 ms	Responded	✓	client.wms.windows.com	40.113.110.67					
				40.126.32.136					
				40.126.32.133					
				20.190.160.22					
10283 ms	Responded	✓	login.live.com	40.126.32.74					
				20.190.160.20					
				20.190.160.14					
				40.126.32.68					
				40.126.32.76					
10285 ms	Responded	✓	ocsp.digicert.com	192.229.221.95					
10286 ms	Responded	✓	settings-win.data.microsoft.com	20.73.194.208					
21534 ms	Responded	⚠	caffegclasiqwp.shop	172.67.215.62					
				104.21.16.180					
23539 ms	Responded	?	arpdabl.zapto.org	0.0.0.0					
27144 ms	Responded	✓	slscr.update.microsoft.com	40.127.169.103					
28145 ms	Responded	✓	www.microsoft.com	23.35.229.160					
28145 ms	Responded	✓	fe3scr.delivery.mp.microsoft.com	13.95.31.18					
28146 ms	Responded	✓	fe3scr.delivery.mp.microsoft.com	13.95.31.18					
28146 ms	Responded	✓	slscr.update.microsoft.com	40.127.169.103					
48566 ms	Responded	✓	nexusrules.officeapps.live.com	52.111.229.48					

Figura 13 – Elenco completo delle sedici richieste DNS effettuate durante la sessione di analisi, con evidenza dei domini sospetti caffegclasiqwp.shop e arpdabl.zapto.org (dominio Dynamic DNS a reputazione incerta).

5.5.3 Alert di Sicurezza di Rete (Motore Suricata / Regole Emerging Threats)

Il motore di analisi del traffico di rete ha generato otto alert distinti (Figura 14), tra i quali si segnalano in particolare:

- **A Network Trojan was detected**: “STEALER [ANY.RUN] Lumma Stealer TLS Connection” (PID 4704), riscontro che ha permesso di correlare il campione anche alla famiglia Lumma Stealer, suggerendo un possibile riutilizzo di infrastruttura o di moduli di rete condivisi tra le due famiglie di malware.

- **ET INFO Executable Download from dotted-quad Host:** alert relativo al download di file eseguibili direttamente da un indirizzo IP numerico, anziché da un nome a dominio, pratica tipica impiegata per eludere controlli basati su reputazione di dominio.
- **ET HUNTING SUSPICIOUS Dotted Quad Host MZ Response:** rilevamento della firma dell'intestazione MZ (caratteristica dei file eseguibili PE di Windows) trasferita tramite connessione diretta a indirizzo IP.
- **ET DROP Spamhaus DROP Listed Traffic Inbound group 23:** traffico proveniente da un intervallo di indirizzi IP inserito nella lista Spamhaus DROP (Don't Route Or Peer), riservata a reti notoriamente associate ad attività illecite.

Process details ID 4704 **Malicious**

RegAsm.exe AI

4.8.9037.0 built by: Microsoft .NET Ass

Username: admin

Start: +20796ms **Indicators:**     

Command line AI

"C:\Windows\Microsoft.NET\Framework\v4.0.30319\RegAsm.exe"

[More Info](#)

Hide all

Danger 5

LUMMA has been detected (YARA)

Stealers network behavior

LUMMA has been detected (SURICATA)

[T1552.001](#) Credentials In Files (1) ▾

└ Actions looks like stealing of personal data

[T1518](#) Software Discovery (1) ▾

└ Actions looks like stealing of personal data

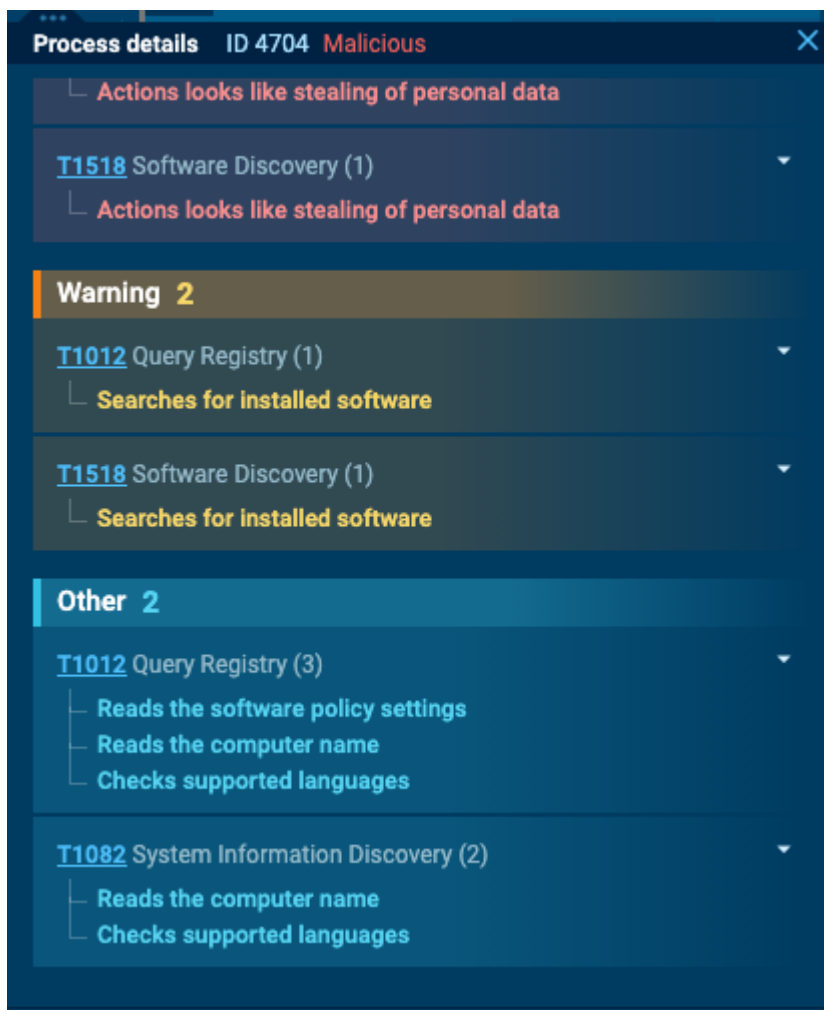


Figura 8 e Figura 9 – Dettaglio del processo RegAsm.exe (PID 4704), con evidenza dei cinque indicatori di pericolo (Danger) correlati al rilevamento delle firme YARA e Suricata per la famiglia Lumma, nonché delle attività di comportamento tipiche degli stealer di rete.

	HTTP Requests	5	Connections	53	DNS Requests	16	Network Threats	8
	Timeshift	Class	PID	Process name	Message			
NETWORK	20409 ms	Potentially Bad Traffic	6908	RegAsm.exe	ET INFO Executable Download from dotted-quad Host			
	20417 ms	Potential Corporate Privacy Violation	6908	RegAsm.exe	ET POLICY PE EXE or DLL Windows file download HTTP			
	20421 ms	Potentially Bad Traffic	6908	RegAsm.exe	ET HUNTING SUSPICIOUS Dotted Quad Host MZ Response			
	20424 ms	Misc Attack	6908	RegAsm.exe	ET DROP Spamhaus DROP Listed Traffic Inbound group 23			
FILES	21446 ms	Potentially Bad Traffic	6908	RegAsm.exe	ET INFO Executable Download from dotted-quad Host			
	21449 ms	A Network Trojan was detected	4704	RegAsm.exe	STEALER [ANY.RUN] Lumma Stealer TLS Connection			
DEBUG	22978 ms	Potentially Bad Traffic	2256	svchost.exe	ET POLICY DNS Query to DynDNS Domain *.zaproto .org			
	89388 ms	Potentially Bad Traffic	6908	RegAsm.exe	ET HUNTING SUSPICIOUS Dotted Quad Host MZ Response			

Figura 14 – Riepilogo degli otto alert di sicurezza generati dal motore di analisi del traffico di rete (Suricata / regole Emerging Threats), classificati per gravità.

5.6 Fase 5 – Persistenza Temporanea, Delay Tattico e Anti-Forensics (Self-Deletion)

Nella fase conclusiva dell'esecuzione, è stato osservato l'avvio di un processo cmd.exe (PID 6284) con la seguente linea di comando:

```
"C:\Windows\system32\cmd.exe" /c timeout /t 10 & rd /s /q "C:\ProgramData\FHJDBKJKFIEC" & exit
```


Tale comportamento è riconducibile alla tecnica T1059.003 – Command and Scripting Interpreter: Windows Command Shell e implementa una strategia di anti-forensics particolarmente efficace: il comando `timeout /t 10` introduce un ritardo di dieci secondi, durante il quale il processo malevolo principale ha modo di terminare la propria esecuzione, rilasciando così il lock esclusivo sui file contenuti nella cartella temporanea di lavoro. Trascorso tale intervallo, il comando `rd /s /q` provvede alla cancellazione ricorsiva e silenziosa della directory `C:\ProgramData\FHJDBKJKFIEC`, eliminando dal disco gran parte delle evidenze artefattuali dell'infezione e ostacolando, conseguentemente, un'eventuale successiva analisi forense post-mortem del sistema.



Figura 11 – Dettaglio del processo `cmd.exe` (PID 6284), con evidenza della tecnica T1059.003 e della linea di comando impiegata per l'eliminazione ritardata e ricorsiva della directory temporanea di lavoro del malware.

6. Indicatori di Compromissione (IoC)

Ai fini della condivisione con la comunità di threat intelligence e dell'eventuale implementazione di regole di rilevamento (SIEM, IDS/IPS, EDR), si riporta di seguito la tabella riepilogativa degli Indicatori di Compromissione estratti nel corso dell'analisi.

6.1 Indirizzi IP e Domini Malevoli

Tipologia	Indicatore	Ruolo
Indirizzo IP C2	147.45.44.104	Server di Command & Control / hosting payload secondari
Dominio	caffegclasiqwp.shop	Dominio C2 associato a firme Suricata
Dominio	arpdabl.zapto.org	Dominio Dynamic DNS per persistenza dell'infrastruttura C2

6.2 Nomi File e Percorsi di Sistema

Percorso / Nome File	Descrizione
C:\ProgramData\HCAEHJKFC.exe	Dropper iniziale
C:\ProgramData\FHJDBKJKFIEC\	Directory temporanea di lavoro, successivamente eliminata
66cb2df8bd684_lawrng.exe	Payload secondario scaricato dal C2 (321 KB)
66cb2df1d4a01_vakerk.exe	Payload secondario scaricato dal C2 (193 KB)

6.3 Hash del Campione Primario

Algoritmo	Valore
MD5	FEB8687ED23F77925B35623027F799BB
Nome file osservato	66bddfcb52736_vidar.exe

7. Mappatura delle Tecniche secondo il Framework MITRE ATT&CK

Al fine di garantire l'interoperabilità dell'analisi con gli standard riconosciuti dalla comunità di sicurezza informatica, si riporta di seguito la mappatura completa delle tecniche osservate secondo la matrice MITRE ATT&CK for Enterprise.

Tattica	Tecnica	ID	Osservazione
Defense Evasion	Masquerading: Rename System Utilities	T1036.003	Iniezione in RegAsm.exe
Discovery	System Information Discovery	T1082	Lettura CPU, GUID, nome host
Discovery	System Location Discovery	T1614	Verifica localizzazione geografica
Discovery	Software Discovery	T1518	Enumerazione software installato
Discovery	Query Registry	T1012	Interrogazione estesa del registro
Discovery	Time Based Evasion	T1497.003	Verifica data installazione OS
Credential Access	Credentials from Web Browsers	T1555.003	Furto password Chromium/Firefox
Credential Access	Steal Web Session Cookie	T1539	Esfiltrazione cookie di sessione
Command and Control	Ingress Tool Transfer	T1105	Download payload secondari da C2
Execution	Windows Command Shell	T1059.003	Script di self-deletion ritardata

8. Considerazioni Finali e Lezioni Apprese

L'esercitazione condotta ha consentito di sviluppare una comprensione approfondita e concreta delle modalità operative impiegate da un campione appartenente alla categoria degli infostealer, con particolare riferimento alle tecniche di evasione, furto di credenziali e anti-forensics tipiche delle famiglie Vidar e Lumma Stealer, tra le più diffuse nel panorama del cybercrime contemporaneo.

Dal punto di vista metodologico, l'attività ha evidenziato l'importanza cruciale dell'analisi dinamica in ambiente sandbox quale strumento imprescindibile per la comprensione del comportamento reale del malware, in special modo laddove le tecniche di offuscamento e process injection impiegate rendano l'analisi statica del solo codice binario insufficiente a una piena caratterizzazione della minaccia.

Sul piano didattico, l'esercizio ha permesso di consolidare competenze trasversali relative:

- alla lettura e interpretazione di report di sandbox automatizzati;
- alla mappatura sistematica delle tecniche osservate secondo il framework MITRE ATT&CK, standard de facto per la comunicazione strutturata delle informazioni di threat intelligence;
- all'estrazione e alla strutturazione degli Indicatori di Compromissione secondo un formato riutilizzabile ai fini della difesa attiva;
- alla correlazione tra evidenze tecniche di basso livello (system call, chiamate di registro, traffico di rete) e le relative implicazioni strategiche in termini di rischio aziendale.

Si segnala, infine, come il caso analizzato costituisca un esempio paradigmatico della crescente convergenza tra famiglie di malware differenti (Vidar e Lumma), fenomeno riconducibile alla natura sempre più modulare e “as-a-service” dell'ecosistema cybercriminale contemporaneo, in linea con quanto osservato a livello di settore in relazione al modello Malware-as-a-Service e Ransomware-as-a-Service.

9. Conclusioni

L'analisi condotta ha permesso di caratterizzare in maniera esaustiva e metodologicamente rigorosa il comportamento di un campione malevolo altamente rappresentativo delle moderne minacce di tipo infostealer, confermando come la combinazione di tecniche di masquerading, process hollowing, furto sistematico di credenziali e meccanismi di anti-forensics costituisca oggi lo standard operativo degli attori di minaccia orientati alla monetizzazione rapida dei dati sottratti.

Il caso di studio dimostra, in particolare, come la sola difesa perimetrale risulti largamente insufficiente a contrastare minacce di tale sofisticazione: solo un approccio integrato, fondato sui principi della defense in depth e dell'architettura Zero Trust, unitamente all'adozione di meccanismi di autenticazione resistenti al phishing e a capacità di rilevamento comportamentale a livello di endpoint e di rete, consente di ridurre in maniera significativa la superficie di attacco esposta e di contenere l'impatto di un'eventuale compromissione.

In una prospettiva più ampia, l'esercitazione conferma quanto affermato nel documento di riferimento circa la natura della cybersecurity quale processo continuo e non quale prodotto statico: la capacità di un'organizzazione di resistere a minacce di questo tipo dipende in ultima analisi dall'integrazione sinergica tra tecnologia, processi strutturati di incident response e, non da ultimo, dalla formazione continua del capitale umano, autentica "linea di difesa" ultima e determinante di fronte all'evoluzione incessante delle tecniche offensive. Tale consapevolezza rappresenta l'esito formativo più rilevante conseguito attraverso la presente esercitazione.

Relazione redatta a fini didattici nell'ambito di un'esercitazione di laboratorio in sicurezza informatica. L'attività descritta è stata condotta esclusivamente in ambiente sandbox isolato, senza alcuna esecuzione, propagazione o interazione del campione analizzato con sistemi di produzione, reti aziendali o infrastrutture reali.